

ResolvX

Internal Audit Report

ISMS Internal Audit – Q2 2026

AUDIT-RPT-002 - July 2026 - Internal - Confidential

Document Information

Document ID	AUDIT-RPT-002
Audit Period	Q1 2026 – April to June 2026
Audit Type	ISO 27001:2022 Clause 9.2 Internal Audit
Lead Auditor	GRC Lead - Derick G. Dmello
Observer / Approver	CISO
Audit Scope	Full ISMS scope: all ResolvX information assets, processes, controls, and personnel
Framework	ISO 27001:2022 Annex A - SOC 2 TSC CC1-CC9 - NIST CSF 2.0
Audit Checklist Reference	AUDIT-CL-001
CAP Reference	AUDIT-CAP-001
Classification	Internal - Confidential

1. Executive Summary

ResolvX conducted its internal ISMS reaudit in Q2 2026, covering 31 ISO 27001:2022 Annex A controls and 17 SOC 2 Trust Service Criteria across all programme phases (Phases 1-4). The audit was conducted by the GRC Lead in accordance with ISO 27001:2022 Clause 9.2 and ISO 27003:2017 guidance on internal audit.

The overall audit result is SATISFACTORY. ResolvX has established a comprehensive ISMS across all key control domains within its first programme year. No major nonconformities were identified. Five minor nonconformities and three observations were raised, all of which have been incorporated into the Corrective Action Plan (AUDIT-CAP-001) with defined owners and deadlines.

Finding Type	ISO 27001	SOC 2	Total
Conformant	22	15	37
Minor Nonconformity	4	1	5
Major Nonconformity	0	0	0
Observation	3	0	3

Overall Audit Verdict: SATISFACTORY - ISMS is fit for purpose at current maturity stage. No certification blocking findings.

Q3 2026 Re-Audit Update (July 2026)

Following delivery of the POL-007–026 policy suite and supporting evidence artifacts, all 5 Minor Nonconformities and 2 of 3 Observations from this audit were re-tested against the original checklist (AUDIT-CL-001). Closure verification is recorded inline within each finding below (§3.1, §3.2). Updated result:

Finding Type	Q1 2026	Q2 2026	Change
Conformant	37	46	+9
Minor Nonconformity	5	0	-5, all closed
Observation	3	2	-1 (F-006 closed); F-007/F-008 remain, F-008 by design

2. Audit Scope and Methodology

2.1 Scope

This audit covered the full ISMS scope as defined in the ResolvX Programme Foundation (Phase 1). The scope includes:

- All information assets classified under POL-004 (Public, Internal, Confidential, Restricted).
- All ResolvX personnel, contractors, and third parties with access to ResolvX systems.
- Cloud infrastructure (AWS eu-west-1, eu-central-1).
- All corporate SaaS applications in the vendor register.
- All policies, the Incident Response Plan, and vendor risk artefacts.
- Processes: risk management, access control, vendor risk, incident response, privacy, change management.

2.2 Methodology

The audit was conducted using a risk-based approach aligned to ISO 27001:2022 Clause 9.2 and ISO/IEC 27003:2017 Section 9.2. Audit methods included:

- Document review: policies, procedures, registers, and artefacts from Phases 1-4.
- Interview: GRC Lead, Head of Cloud Ops, IT Admin, DevSecOps Engineer.
- Observation: system configuration reviews (Okta, AWS, Jamf, Snyk, GitHub).
- Sampling: access reviews (5 leavers), document classification (10 documents), training records (20 employees).
- Technical testing: MFA enforcement verification, TLS configuration check, S3 encryption confirmation.

2.3 Audit Criteria

Controls were assessed against: ISO/IEC 27001:2022 Annex A requirements; SOC 2 Trust Service Criteria (AICPA 2017); ResolvX information security policies; NIST CSF 2.0 applicable subcategories; applicable legal and regulatory requirements (GDPR, Irish DPC guidance).

3. Audit Findings

3.1 Minor Nonconformities

The following five minor nonconformities were identified. Each has a corresponding corrective action in AUDIT-CAP-001.

A5.12 / POL-004 - Data Classification Labelling

NC-001	Minor NC	2 of 10 sampled documents lacked classification labels. POL-004 requires all documents to carry a classification label at creation. The policy was published but the labelling workflow was not operationalised in Google Workspace document templates.
Root Cause	Action Required	
POL-004 published without corresponding template updates or workflow enforcement	Add classification labels to Workspace templates; retrain document owners; re-test sample (F-001)	Closed — see Closure Verification below (July 2026)

Closure Verification — Q2 2026 Re-Audit: CLOSED

Classification label templates added to Google Workspace document templates; document creation workflow reminder configured; document owners re-trained on labelling requirements. Re-test of the original 10-document sample (July 2026) confirmed all documents correctly labelled. Formalised under POL-004.

A5.17 / CC6.1 - Hardware Key Enforcement for Admin Accounts

NC-002	Minor NC	POL-003 and the vendor assessment framework require hardware FIDO2 keys for privileged account authentication. Okta policy for the admin group has not yet been updated to enforce hardware key requirement - 8 admin accounts still using TOTP-based MFA only.
Root Cause	Action Required	
Hardware key procurement delayed; Okta policy change deprioritised	Procure FIDO2 keys for all 8 admin accounts; update Okta admin group policy; verify enforcement (F-002)	Closed — see Closure Verification below (July 2026)

Closure Verification — Q2 2026 Re-Audit: CLOSED

FIDO2 hardware keys procured and distributed to all 8 admin accounts; Okta admin group policy configured to enforce hardware key authentication; enforcement validated via Okta admin console (July 2026). Formalised under POL-012 §5 (break-glass credential handling) and POL-003.

A5.23 - SSO Coverage for Corporate SaaS

NC-003	Minor NC	2 legacy SaaS integrations in the vendor register are not connected to Okta SSO despite POL-005 requiring all corporate SaaS to authenticate via Okta. Both tools were onboarded before the SSO policy was formalised.
Root Cause	Action Required	
Tools onboarded pre-policy; migration deprioritised	Configure Okta SAML/OIDC for both tools; migrate authentication; update vendor register (F-003)	Closed — see Closure Verification below (July 2026)

Closure Verification — Q2 2026 Re-Audit: CLOSED

Both legacy SaaS integrations migrated to Okta SSO (SAML/OIDC); Okta application directory confirms 14/14 vendor coverage; vendor register updated. Formalised under POL-005.

A6.3 / CC2.2 - Security Awareness Training Completion

NC-004	Minor NC	Annual security awareness training completion rate is 93% (112/120 employees). 8 employees are overdue beyond the 30-day grace period. POL-002 requires all staff to complete annual security awareness training.
Root Cause	Action Required	
No automated escalation when training is overdue; manager notification not triggered	Escalate to line managers for 8 overdue employees; configure LMS automation for future cycles (F-004)	Closed — see Closure Verification below (July 2026)

Closure Verification — Q2 2026 Re-Audit: CLOSED

All 8 previously-overdue employees completed security awareness training; training completion now 120/120 (100%). Automated LMS escalation on overdue training configured for future cycles, per POL-023 §5's training-tracking requirement.

A8.8 / CC7.1 - Vulnerability Patch SLA Compliance

NC-005	Minor NC	2 High severity findings in Snyk have been open for more than 30 days, exceeding the 30-day patch SLA defined in the Information Security Policy (POL-001). Both findings are tracked in Snyk but not assigned to an active engineering sprint.
Root Cause	Action Required	
Engineering sprint prioritisation did not include vulnerability backlog; no automated SLA escalation	Assign both findings to current sprint; configure Snyk-Jira integration for automated ticket creation on High findings (F-005)	Closed — see Closure Verification below (July 2026)

Closure Verification — Q2 2026 Re-Audit: CLOSED

Both High-severity Snyk findings remediated within the assigned sprint. Snyk-to-Jira integration configured for automatic ticket creation on High/Critical findings, per POL-010 §6.1. Snyk report (July 2026) confirms 0 open High-severity findings older than 30 days.

3.2 Observations

The following three observations are not nonconformities but represent opportunities for improvement that will strengthen the ISMS as ResolvX scales.

A5.9 - Formal Asset Register

OBS-001	Observation	An asset inventory exists within the programme foundation documents but is not maintained as a standalone, formally controlled ISMS document with a defined review cycle and named owner. As ResolvX scales, a formal asset register will be increasingly important for scope management.
Root Cause	Action Required	
Asset inventory created as scoping artefact; not yet formalised as ISMS document	Formalise as standalone ISMS document with document ID, version control, named owner, and annual review (F-006)	Closed — see Closure Verification below (July 2026)

Closure Verification — Q2 2026 Re-Audit: CLOSED

Formalised as POL-011 (Asset Management Policy) — Document ID POL-011, version-controlled, GRC Lead ownership, annual review cycle. Satisfies the original recommendation in full.

A5.28 - Evidence Handling - Not Yet Field Tested

OBS-002	Observation	Evidence handling procedures are documented in IR-PLAN-001 Section 5 but have not been tested in a real P1/P2 incident or as a dedicated exercise inject. The Feb 2026 tabletop did not include evidence chain-of-custody as a specific test.
Root Cause	Action Required	
No P1/P2 incident to date; evidence handling not included in tabletop injects	Include evidence handling as a specific inject in Tabletop Exercise 2 (Aug 2026) (F-007)	Still open — see Closure Verification below. AUDIT-CAP-001 tracks current status.

Closure Verification — Q2 2026 Re-Audit: STILL OPEN

An Evidence/Chain-of-Custody Log template now exists (Incident Response Plan Appendix B, added July 2026), closing the tooling gap this observation implicitly assumed. However, it has still not been exercised in a real P1/P2 incident or a dedicated tabletop inject — the observation remains open on its own terms until that test occurs.

A8.12 - DLP Coverage Scope

OBS-003	Observation	Current DLP controls are limited to Google Workspace email and Drive rules. There is no dedicated DLP tooling covering API traffic, S3 egress, or endpoint data exfiltration channels. At current scale this is acceptable, but as data processing volume grows, expanded DLP coverage should be assessed.
Root Cause	Action Required	
Current DLP scope deemed adequate at programme inception; not yet a material gap	Assess dedicated DLP tooling (AWS Macie, CASB); document residual risk if expansion deferred (F-008)	Open by design (risk accepted) — see Closure Verification below. AUDIT-CAP-001 tracks current status.

Closure Verification — Q2 2026 Re-Audit: OPEN BY DESIGN — FORMAL RISK ACCEPTANCE

POL-019 (DLP Policy) now formally documents current scope (Workspace email/Drive), a phased roadmap (AWS Macie for S3, then CASB), and a CISO-accepted residual risk for the remaining coverage gap under POL-014 §5's tiered authority. This observation intentionally remains open as a documented, owned decision rather than an unaddressed gap.

4. Positive Findings and Strengths

The following areas demonstrated strong control implementation and were rated Conformant with no gaps identified:

Policy Suite (A5.1)	All policies are in place, approved by the CISO, and current. Policy coverage is comprehensive for a company at this maturity stage.
Vendor Risk Management (A5.19 / CC9.1-9.2)	Tier 1 vendor assessments completed for all 6 critical vendors; DPAs in place for all data-processing vendors; sub-processor register maintained. TPRM framework is audit ready.
Incident Response (A5.24-A5.27 / CC7.3-7.5)	IR plan, 3 runbooks, tabletop exercise, and incident log template all in place and tested. Tabletop findings remediated promptly. IR programme is strong for a first-year ISMS.
Access Control (A5.15 / CC6.1-6.7)	MFA enforced for 100% of users; RBAC via Okta; quarterly access review conducted; JML process implemented and evidenced. No unauthorised access found in sampled review.
Privacy Programme (A5.34)	ROPA covering 9 processing activities; DSR process documented; GDPR processor/controller distinction correctly implemented; breach notification procedures aligned to 72-hour GDPR obligation.
Cryptography (A8.24)	AES-256 at rest and TLS 1.3 in transit confirmed across all production systems. KMS key management in place. No unencrypted sensitive data storage identified.
Monitoring and Logging (A8.15-A8.16)	CloudTrail with integrity validation enabled across all AWS regions; Okta and Datadog monitoring active; alert review cadence documented.

5. Conclusion and Recommendations

Overall Audit Verdict: SATISFACTORY

ResolvX has successfully established a comprehensive ISMS in its first programme year. The control framework covers all required domains under ISO 27001:2022 and SOC 2 Trust Service Criteria. The absence of major nonconformities is notable for an internal audit and reflects the quality and completeness of the Phase 1-4 programme deliverables.

Updated July 2026: all five minor nonconformities have since been closed and re-tested against the original checklist (see closure verification in §3.1). Of the three observations, one (asset register) is closed; evidence handling remains genuinely untested pending a dedicated exercise, and DLP scope remains open by design as a documented, CISO-accepted residual risk rather than an unaddressed gap.

5.1 Recommendations for Phase 6

- ✓ DONE (July 2026) — all 5 minor nonconformities closed and re-tested.
- ✓ DONE (July 2026) — formalised as POL-011.
- STILL OPEN — template built (IR Plan Appendix B), not yet exercised; recommend a dedicated evidence-handling tabletop.
- NEW PRIORITY — engage an external SOC 2 Type II auditor; this is now the single largest remaining gate (see SOC 2 Readiness Assessment).
- Consider a limited-scope penetration test to validate technical controls ahead of Phase.

6. Document Control

Document ID	AUDIT-RPT-002
Audit Date	Q2 2026
Report Date	2026-07-31
Prepared By	GRC Lead - Derick G. Dmello
Reviewed By	CISO
Classification	Internal - Confidential
Retention	5 years
Next Audit	Q1 2027 (annual cycle) — Q2 2026 re-audit of prior findings; full annual cycle remains Q1 2027
Related Documents	AUDIT-CL-001 (Checklist) - AUDIT-CAP-001 (CAP) - AUDIT-SOC2-001 (SOC 2 Readiness)

Role	Name	Signature / Date
Lead Auditor / GRC Lead	Derick G. Dmello	
Approver / CISO		